

Introduction to Nmap

What is Nmap?

Nmap (Network Mapper) is a powerful, widely used open-source tool in Kali Linux. They scan network targets, identify the operating system and open ports, and scan the vulnerabilities. This is the main tool used in Ethical Hacking and penetration testing.

What is Port, Host, and Service?

A **port** is a virtual communication endpoint on a device. They are Used to send and receive data between systems over a network.

Example: 21 → FTP

A **host** is any device (computer, server, router) connected to a network. It is identified by an IP address (e.g., 192.168.1.1). Hosts can have multiple open ports running different services.

A **service** is an application running on a host that listens on a specific port.

Example:

Apache (HTTP server) → Runs on port 80

OpenSSH (Secure Shell) → Runs on port 22

How to install Nmap?

Run the following command in the Kali Linux terminal:

```
sudo apt install nmap -y
```

Check the version of Nmap (Verify the installation):

```
nmap --version
```

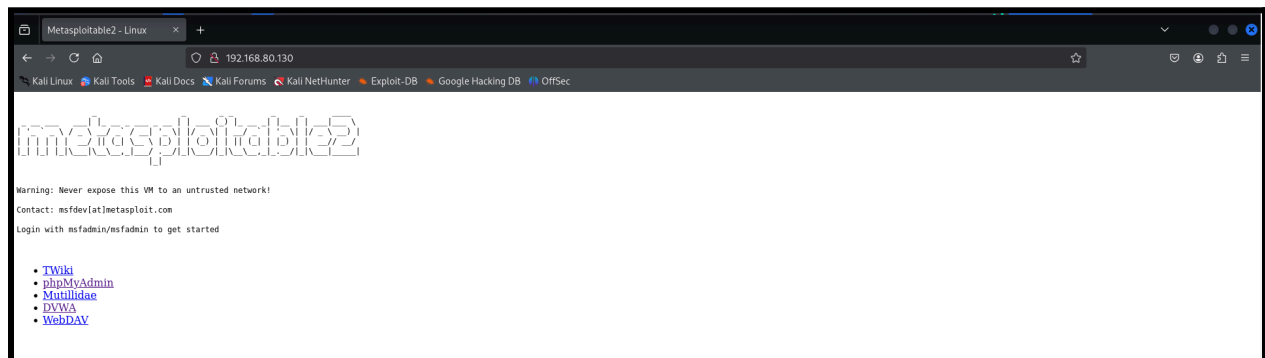
If the version is showing then the installation is completed.

Steps to start a Nmap scanning:

Firstly we need to install Metasploitable 2 from the respective website and turn on the Metasploit system. In the Kali terminal first of all we should update Kali using **sudo apt update && sudo apt upgrade -y** and we must know the IP address of the targeted system, for that we need to use the following command: **arp -a**, this command will display the ARP table (Address Resolution Protocol) in the terminal listing all the IP addresses that are connected to the Local host.

```
(kali@kali)-[~]
$ arp -a
? (192.168.80.254) at 00:50:56:f3:d3:70 [ether] on eth0
? (192.168.80.2) at 00:50:56:e8:49:be [ether] on eth0
? (192.168.80.130) at 00:0c:29:fa:dd:2a [ether] on eth0
```

Here, there are IP addresses, including our windows, routers, and metasploitable. The 192.168.80.2 is reserved for Routers and the first one is the IP address of the windows, so that the last IP address (192.168.80.130) is the targeting system, we run the IP in the web browser to load the page.



So our targeted system IP address we have got, we need to scan the IP address with the Nmap tool. There are so many scanning tools available, Nmap is the most used network scanning tool.

Pinging the Targeted IP

This command can be used to identify the Operating System of the targeted IP, we can use the **ping**. ttl=64 is the default Linux OS.

```
(kali㉿kali)-[~]  
$ ping 192.168.80.130  
PING 192.168.80.130 (192.168.80.130) 56(84) bytes of data.  
64 bytes from 192.168.80.130: icmp_seq=1 ttl=64 time=2.03 ms  
64 bytes from 192.168.80.130: icmp_seq=2 ttl=64 time=1.60 ms  
64 bytes from 192.168.80.130: icmp_seq=3 ttl=64 time=1.65 ms  
64 bytes from 192.168.80.130: icmp_seq=4 ttl=64 time=2.21 ms  
64 bytes from 192.168.80.130: icmp_seq=5 ttl=64 time=1.21 ms  
64 bytes from 192.168.80.130: icmp_seq=6 ttl=64 time=2.56 ms  
64 bytes from 192.168.80.130: icmp_seq=7 ttl=64 time=1.40 ms  
64 bytes from 192.168.80.130: icmp_seq=8 ttl=64 time=1.30 ms  
64 bytes from 192.168.80.130: icmp_seq=9 ttl=64 time=1.63 ms  
64 bytes from 192.168.80.130: icmp_seq=10 ttl=64 time=2.60 ms  
^C  
--- 192.168.80.130 ping statistics ---  
10 packets transmitted, 10 received, 0% packet loss, time 9018ms  
rtt min/avg/max/mdev = 1.213/1.819/2.602/0.478 ms
```

Running the Nmap using Commands:

- **nmap -sV 192.168.80.130**
 - This is the command used for service version detection of the targeted IP.
 - We can get many details about the targeted IP

```
(kali㉿kali)-[~]
$ nmap -sV 192.168.80.130
Starting Nmap 7.95 ( https://nmap.org ) at 2025-03-08 00:35 EST
Nmap scan report for 192.168.80.130
Host is up (0.0012s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rshcd
513/tcp   open  login        OpenBSD or Solaris rlogind
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 00:0C:29:FA:DD:2A (VMware)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.75 seconds
```

After the scan:

- We have got the details that the version of nmap is 7.95
 - They have scanned 1000 ports (default) and found 23 open ports.
 - Some potential risks and vulnerabilities can be exploited.
-

- **nmap -p- 192.168.80.130**
 - This command will scan all 65,535 ports on the target machine.

```
(kali㉿kali)-[~]
$ nmap -p- 192.168.80.130
Starting Nmap 7.95 ( https://nmap.org ) at 2025-03-08 00:38 EST
Nmap scan report for 192.168.80.130
Host is up (0.0019s latency).
Not shown: 65505 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
3632/tcp  open  distccd
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
6697/tcp  open  ircs-u
8009/tcp  open  ajp13
8180/tcp  open  unknown
8787/tcp  open  msgsrvr
38210/tcp open  unknown
48139/tcp open  unknown
48934/tcp open  unknown
55637/tcp open  unknown
MAC Address: 00:0C:29:FA:DD:2A (VMware)
```

After the scan:

- Nmap scans all 65,535 TCP ports and provides an output listing:
 - Open Ports (services currently running and accessible).
 - Closed Ports (ports that respond but reject connections).
 - Filtered Ports (ports blocked by a firewall or network rules).

- **nmap -sV -sC 192.168.80.130**
 - performs a detailed scan by combining:
 - **-sV (Service Version Detection)** → Identifies running services and their versions.
 - **-sC (Default Script Scan)** → Runs Nmap's default scripts to check for vulnerabilities, misconfigurations, and additional information.

```

kali@kali:~$ nmap -sV -sC 192.168.80.130
Starting Nmap 7.95 ( https://nmap.org ) at 2025-03-08 00:40 EST
Nmap scan report for 192.168.80.130
Host is up (0.0010s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ftp-syst:
|_STAT:
|_FTP server status:
|_Connected to 192.168.80.128
|_Logged in as ftp
|_TYPE: ASCII
|_No session bandwidth limit
|_Session timeout in seconds is 300
|_Control connection is plain text
|_Data connections will be plain text
|_vsFTPD 2.3.4 - secure, fast, stable
|_End of status
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
ssh-hostkey:
|_1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
|_smtp_commands: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITIME, DSN
|_ssl-date: 2025-03-08T05:40:58+00:00; +3s from scanner time.
sslv2:
|_SSLv2 supported
|_ciphers:
|_SSL2_DES_192_EDE3_CBC_WITH_MD5
|_SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
|_SSL2_RC2_128_CBC_WITH_MD5
|_SSL2_RC4_128_WITH_MD5
|_SSL2_RC4_128_EXPORT40_WITH_MD5
|_SSL2_DES_64_CBC_WITH_MD5
|_ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX

ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
Not valid before: 2010-03-17T14:07:45
Not valid after: 2010-04-16T14:07:45
53/tcp    open  domain       ISC BIND 9.4.2
dns-nsid:
|_bind.version: 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_http_server_header: Apache/2.2.8 (Ubuntu) DAV/2
|_http_title: Metasploitable2 - Linux
111/tcp   open  rpcbind      2 (RPC #100000)
rpcinfo:
|_program version port/proto service
|_100000 2 111/tcp rpcbind
|_100000 2 111/udp rpcbind
|_100003 2,3,4 2049/tcp nfs
|_100003 2,3,4 2049/udp nfs
|_100005 1,2,3 55311/udp mountd
|_100005 1,2,3 55637/tcp mountd
|_100021 1,3,4 34541/udp nlockmgr
|_100021 1,3,4 48934/tcp nlockmgr
|_100024 1 42593/udp status
|_100024 1 48139/tcp status
139/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rshcd
513/tcp   open  login        OpenBSD or Solaris rlogind
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
mysql-info:
|_Protocol: 10
|_Version: 5.0.51a-3ubuntu5
|_Thread ID: 9
|_Capabilities flags: 43564
|_Some Capabilities: SupportsTransactions, Support41Auth, LongColumnFlag, SupportsCompression, Speaks41ProtocolNew, SwitchToSSLAfterHandshake, ConnectWithDatabase
|_Status: Autocommit
|_Salt: 6Gp~L>2-Ejda7.)Q\Y-p

```

```

2121/tcp open  ftp          ProFTPD 1.3.1
3306/tcp open  mysql          MySQL 5.0.51a-3ubuntu5
mysql-info:
  Protocol: 10
  Version: 5.0.51a-3ubuntu5
  Thread ID: 9
  Capabilities flags: 43564
  Some Capabilities: SupportsTransactions, Support41Auth, LongColumnFlag, SupportsCompression, Speaks41ProtocolNew, SwitchToSSLAfterHandshake, ConnectWithDatabase
  Status: Autocommit
  Salt: 6Gp~L>2-E[da7.]Q\Y-p
5432/tcp open  postgresql PostgreSQL DB 8.3.0 - 8.3.7
ssl-date: 2025-03-08T05:40:58+00:00; +3s from scanner time.
ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
Not valid before: 2010-03-17T14:07:45
Not valid after: 2010-04-16T14:07:45
5900/tcp open  vnc            VNC (protocol 3.3)
vnc-info:
  Protocol version: 3.3
  Security types:
  VNC Authentication (2)
6000/tcp open  X11            (access denied)
6667/tcp open  irc            UnrealIRCd
irc-info:
  users: 1
  servers: 1
  lusers: 1
  lservers: 0
  server: irc.Metasploitable.LAN
  version: Unreal3.2.8.1. irc.Metasploitable.LAN
  uptime: 0 days, 0:26:44
  source ident: nmap
  source host: 6A7C70E2.20810D6C.FFFA6D49.IP
  error: Closing Link: ewxycdhuo[192.168.80.128] (Quit: ewxycdhuo)
8009/tcp open  ajp13          Apache Jserv (Protocol v1.3)
ajp-methods: Failed to get a valid response for the OPTION request
8180/tcp open  http           Apache Tomcat/Coyote JSP engine 1.1
http-favicon: Apache Tomcat
http-title: Apache Tomcat/5.5
http-server-header: Apache-Coyote/1.1
MAC Address: 00:0C:29:FA:DD:2A (VMware)

```

```

  servers: 1
  lusers: 1
  lservers: 0
  server: irc.Metasploitable.LAN
  version: Unreal3.2.8.1. irc.Metasploitable.LAN
  uptime: 0 days, 0:26:44
  source ident: nmap
  source host: 6A7C70E2.20810D6C.FFFA6D49.IP
  error: Closing Link: ewxycdhuo[192.168.80.128] (Quit: ewxycdhuo)
8009/tcp open  ajp13          Apache Jserv (Protocol v1.3)
ajp-methods: Failed to get a valid response for the OPTION request
8180/tcp open  http           Apache Tomcat/Coyote JSP engine 1.1
http-favicon: Apache Tomcat
http-title: Apache Tomcat/5.5
http-server-header: Apache-Coyote/1.1
MAC Address: 00:0C:29:FA:DD:2A (VMware)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
smb-os-discovery:
  OS: Unix (Samba 3.0.20-Debian)
  Computer name: metasploitable
  NetBIOS computer name:
  Domain name: localdomain
  FQDN: metasploitable.localdomain
  System time: 2025-03-08T00:40:49-05:00
_nbstat: NetBIOS name: METASPLOITABLE, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
smb-security-mode:
  account_used: <blank>
  authentication_level: user
  challenge_response: supported
  message_signing: disabled (dangerous, but default)
_clock-skew: mean: 1h15m02s, deviation: 2h30m00s, median: 2s
_smb2-time: Protocol negotiation failed (SMB2)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 21.02 seconds

```

After the scan:

- Nmap scans all 65,535 TCP ports and provides an output listing:
 - Analyze Open Ports & Services
 - Identify Possible Vulnerabilities
 - Explore Web Services (If Port 80/443 is Open)
 - Exploit Weak Services.

- **nmap --script=vuln 192.168.80.130**
 - This command scans 192.168.80.130 for known vulnerabilities using Nmap's vuln script category. It checks for:
 - Weak configurations.
 - Outdated software.
 - Common exploits.

```
(kali㉿kali)-[~]
$ nmap --script=vuln 192.168.80.130
Starting Nmap 7.95 ( https://nmap.org ) at 2025-03-08 01:00 EST
Nmap scan report for 192.168.80.130
Host is up (0.00066s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
| ssl-poodle:
| VULNERABLE:
|   SSL POODLE information leak
|   State: VULNERABLE
|   IDs: BID:70574 CVE:CVE-2014-3566
|   • The SSL protocol 3.0, as used in OpenSSL through 1.0.1i and other
|   • products, uses nondeterministic CBC padding, which makes it easier
|   • for man-in-the-middle attackers to obtain cleartext data via a
|   • padding-oracle attack, aka the "POODLE" issue.
|   • Disclosure date: 2014-10-14
|   Check results:
|     TLS_RSA_WITH_AES_128_CBC_SHA
|   References:
|     https://www.imperialviolet.org/2014/10/14/poodle.html
|     https://www.securityfocus.com/bid/70574
|     https://www.openssl.org/~bodo/ssl-poodle.pdf
|     https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2014-3566
|_ smtp-vuln-cve2010-4344:
|   The SMTP server is not Exim: NOT VULNERABLE
|_ sslv2-drown: ERROR: Script execution failed (use -d to debug)
| ssl-dh-params:
| VULNERABLE:
|   Anonymous Diffie-Hellman Key Exchange MitM Vulnerability
|   State: VULNERABLE
|   Transport Layer Security (TLS) services that use anonymous
|   Diffie-Hellman key exchange only provide protection against passive
|   eavesdropping, and are vulnerable to active man-in-the-middle attacks
```



```

State: VULNERABLE
Transport Layer Security (TLS) services that use Diffie-Hellman groups
of insufficient strength, especially those using one of a few commonly
shared groups, may be susceptible to passive eavesdropping attacks.
Check results:
WEAK DH GROUP 1
  Cipher Suite: TLS_DHE_RSA_WITH_AES_128_CBC_SHA
  Modulus Type: Safe prime
  Modulus Source: postfix builtin
  Modulus Length: 1024
  Generator Length: 8
  Public Key Length: 1024

References:
  https://weakdh.org
53/tcp open domain
80/tcp open http
http-slowloris-check:
  VULNERABLE:
    Slowloris DOS attack
    State: LIKELY VULNERABLE
    IDs: CVE:CVE-2007-6750
    Slowloris tries to keep many connections to the target web server open and hold
    them open as long as possible. It accomplishes this by opening connections to
    the target web server and sending a partial request. By doing so, it starves
    the http server's resources causing Denial Of Service.

Disclosure date: 2009-09-17
References:
  https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2007-6750
  http://hacker.org/slowloris/
http-trace: TRACE is enabled
http-fileupload-exploiter:

  Couldn't find a file-type field.
http-dombased-xss: Couldn't find any DOM based XSS.
http-vuln-cve2017-1001000: ERROR: Script execution failed (use -d to debug)
http-stored-xss: Couldn't find any stored XSS vulnerabilities.
http-sql-injection:
  Possible sqli for queries:
    http://192.168.80.130:80/mutillidae/index.php?page=text-file-viewer.php%27%200R%20sqlspider

```

```

http-stored-xss: Couldn't find any stored XSS vulnerabilities.
http-sql-injection:
  Possible sqli for queries:
    http://192.168.80.130:80/mutillidae/index.php?page=text-file-viewer.php%27%200R%20sqlspider
    http://192.168.80.130:80/mutillidae/index.php?page=captured-data.php%27%200R%20sqlspider
    http://192.168.80.130:80/mutillidae/index.php?page=browser-info.php%27%200R%20sqlspider
    http://192.168.80.130:80/mutillidae/index.php?page=installation.php%27%200R%20sqlspider
    http://192.168.80.130:80/mutillidae/index.php?page=credits.php%27%200R%20sqlspider
    http://192.168.80.130:80/mutillidae/index.php?page=show-log.php%27%200R%20sqlspider
    http://192.168.80.130:80/mutillidae/?page=user-info.php%27%200R%20sqlspider
    http://192.168.80.130:80/mutillidae/index.php?page=add-to-your-blog.php%27%200R%20sqlspider
    http://192.168.80.130:80/mutillidae/?page=show-log.php%27%200R%20sqlspider
    http://192.168.80.130:80/mutillidae/?page=view-someones-blog.php%27%200R%20sqlspider
    http://192.168.80.130:80/mutillidae/index.php?page=user-info.php%27%200R%20sqlspider
    http://192.168.80.130:80/mutillidae/index.php?page=register.php%27%200R%20sqlspider
    http://192.168.80.130:80/mutillidae/index.php?page=source-viewer.php%27%200R%20sqlspider
    http://192.168.80.130:80/mutillidae/?page=credits.php%27%200R%20sqlspider
    http://192.168.80.130:80/mutillidae/index.php?page=pen-test-tool-lookup.php%27%200R%20sqlspider
    http://192.168.80.130:80/mutillidae/index.php?page=documentation%2FHow-to-access-Mutillidae-over-Virtual-Box-network.php%27%200R%20sqlspider
    http://192.168.80.130:80/mutillidae/index.php?page=documentation%2Fvulnerabilities.php%27%200R%20sqlspider
    http://192.168.80.130:80/mutillidae/?page=add-to-your-blog.php%27%200R%20sqlspider
    http://192.168.80.130:80/mutillidae/index.php?page=home.php%27%200R%20sqlspider
    http://192.168.80.130:80/mutillidae/index.php?page=login.php%27%200R%20sqlspider
    http://192.168.80.130:80/mutillidae/index.php?page=change-log.htm%27%200R%20sqlspider
    http://192.168.80.130:80/mutillidae/?page=text-file-viewer.php%27%200R%20sqlspider
    http://192.168.80.130:80/mutillidae/index.php?page=notes.php%27%200R%20sqlspider
    http://192.168.80.130:80/mutillidae/index.php?page=framing.php%27%200R%20sqlspider
    http://192.168.80.130:80/mutillidae/?page=source-viewer.php%27%200R%20sqlspider
    http://192.168.80.130:80/mutillidae/index.php?page=secret-administrative-pages.php%27%200R%20sqlspider
    http://192.168.80.130:80/mutillidae/index.php?page=arbitrary-file-inclusion.php%27%200R%20sqlspider
    http://192.168.80.130:80/mutillidae/index.php?page=html5-storage.php%27%200R%20sqlspider
    http://192.168.80.130:80/mutillidae/index.php?page=usage-instructions.php%27%200R%20sqlspider
    http://192.168.80.130:80/mutillidae/index.php?username=anonymous&page=password-generator.php%27%200R%20sqlspider
    http://192.168.80.130:80/mutillidae/index.php?page=site-footer-xss-discussion.php%27%200R%20sqlspider
    http://192.168.80.130:80/mutillidae/index.php?do=toggle-hints%27%200R%20sqlspider&page=home.php
    http://192.168.80.130:80/mutillidae/index.php?page=capture-data.php%27%200R%20sqlspider
    http://192.168.80.130:80/mutillidae/index.php?do=toggle-security%27%200R%20sqlspider&page=home.php
    http://192.168.80.130:80/mutillidae/?page=login.php%27%200R%20sqlspider
    http://192.168.80.130:80/mutillidae/index.php?page=user-poll.php%27%200R%20sqlspider
    http://192.168.80.130:80/mutillidae/index.php?page=view-someones-blog.php%27%200R%20sqlspider

```

```

Possible sql for forms:
  Form at path: /mutillidae/, form's action: ./index.php?page=user-info.php. Fields that might be vulnerable:
  username
http-enum:
  /tikiwiki/: Tikiwiki
  /test/: Test page
  /phpinfo.php: Possible information file
  /phpMyAdmin/: phpMyAdmin
  /doc/: Potentially interesting directory w/ listing on 'apache/2.2.8 (ubuntu) dav/2'
  /icons/: Potentially interesting folder w/ directory listing
  /index/: Potentially interesting folder
http-csrf:
  Spidering limited to: maxdepth=3; maxpagecount=20; withinhost=192.168.80.130
  Found the following possible CSRF vulnerabilities:
    • Path: http://192.168.80.130:80/dvwa/
    • Form id:
    • Form action: login.php

    Path: http://192.168.80.130:80/twiki/TWikiDocumentation.html
    Form id:
    Form action: http://TWiki.org/cgi-bin/passwd/TWiki/WebHome

    Path: http://192.168.80.130:80/twiki/TWikiDocumentation.html
    Form id:
    Form action: http://TWiki.org/cgi-bin/passwd/Main/WebHome

    Path: http://192.168.80.130:80/twiki/TWikiDocumentation.html
    Form id:
    Form action: http://TWiki.org/cgi-bin/edit/TWiki/

    Path: http://192.168.80.130:80/twiki/TWikiDocumentation.html
    Form id:
    Form action: http://TWiki.org/cgi-bin/view/TWiki/TWikiSkins

```

```

VULNERABLE:
SSL/TLS MITM vulnerability (CCS Injection)
  State: VULNERABLE
  Risk factor: High
  Summary: OpenSSL before 0.9.8za, 1.0.0 before 1.0.0m, and 1.0.1 before 1.0.1h
  Details: does not properly restrict processing of ChangeCipherSpec messages,
  Impact: which allows man-in-the-middle attackers to trigger use of a zero
  PoC: length master key in certain OpenSSL-to-OpenSSL communications, and
  Login with: consequently hijack sessions or obtain sensitive information, via
  a crafted TLS handshake, aka the "CCS Injection" vulnerability.

  References:
  • CVE https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2014-0224
  • MD http://www.cvedetails.com/cve/2014-0224
  • DV http://www.openssl.org/news/secadv_20140605.txt
ssl-dh-params:
VULNERABLE:
Diffie-Hellman Key Exchange Insufficient Group Strength
  State: VULNERABLE
  Transport Layer Security (TLS) services that use Diffie-Hellman groups
  of insufficient strength, especially those using one of a few commonly
  shared groups, may be susceptible to passive eavesdropping attacks.
  Check results:
    WEAK DH GROUP 1
      Cipher Suite: TLS_DHE_RSA_WITH_AES_128_CBC_SHA
      Modulus Type: Safe prime
      Modulus Source: Unknown/Custom-generated
      Modulus Length: 1024
      Generator Length: 8
      Public Key Length: 1024
  References:
    https://weakdh.org
ssl-poodle:

```

```

Disclosure date: 2009-09-17 19:16:50
References:
  https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2007-6750
  http://ha.ckers.org/slowloris/
http-enum:
  /admin/: Possible admin folder
  /admin/index.html: Possible admin folder
  /admin/login.html: Possible admin folder
  /admin/admin.html: Possible admin folder
  /admin/account.html: Possible admin folder
  /admin/admin_login.html: Possible admin folder
  /admin/home.html: Possible admin folder
  /admin/admin-login.html: Possible admin folder
  /admin/adminLogin.html: Possible admin folder
  /admin/controlpanel.html: Possible admin folder
  /admin/cp.html: Possible admin folder
  /admin/index.jsp: Possible admin folder
  /admin/login.jsp: Possible admin folder
  /admin/admin.jsp: Possible admin folder
  /admin/home.jsp: Possible admin folder
  /admin/controlpanel.jsp: Possible admin folder
  /admin/admin-login.jsp: Possible admin folder
  /admin/cp.jsp: Possible admin folder
  /admin/account.jsp: Possible admin folder
  /admin/admin_login.jsp: Possible admin folder
  /admin/adminLogin.jsp: Possible admin folder
  /manager/html/upload: Apache Tomcat (401 Unauthorized)
  /manager/html: Apache Tomcat (401 Unauthorized)
  /admin/view/javascript/fckeditor/editor/filemanager/connectors/test.html: OpenCart/FCKeditor File upload
  /admin/includes/FCKeditor/editor/filemanager/upload/test.html: ASP Simple Blog / FCKeditor File Upload
  /admin/jscript/upload.html: Lizard Cart/Remote File upload
  /webdav/: Potentially interesting folder
MAC Address: 00:0C:29:FA:DD:2A (VMware)

Host script results:
|_smb-vuln-ms10-061: false
|_smb-vuln-ms10-054: false
|_smb-vuln-regsvc-dos: ERROR: Script execution failed (use -d to debug)

Nmap done: 1 IP address (1 host up) scanned in 322.66 seconds

```

After the scan:

- After nmap --script=vuln 192.168.80.130 Scan
 - Review Scan Results → Identify vulnerable services & CVEs.
 - Research Exploits → Use Exploit-DB, CVE database, or search-sploit..
 - Exploit Vulnerabilities → Use Metasploit, Hydra, or manual exploitation.
 - Run Deeper Scans → Use nmap -A, nmap -p-, or SMB-specific scans.
 - Secure the System (If Testing Own Network) → Close ports, update software, and improve security.

- **nmap -A 192.168.80.130**

- The -A option in Nmap enables aggressive scanning,

```
(kali@kali)~$ nmap -A 192.168.80.130
Starting Nmap 7.95 ( https://nmap.org ) at 2025-03-08 01:10 EST
Nmap scan report for 192.168.80.130
Host is up (0.0015s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp           vsftpd 2.3.4
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ftp-syst:
|_STAT:
|_FTP server status:
|_  Connected to 192.168.80.128
|_  Logged in as ftp
|_  TYPE: ASCII
|_  No session bandwidth limit
|_  Session timeout in seconds is 300
|_  Control connection is plain text
|_  Data connections will be plain text
|_vsFTPd 2.3.4 - secure, fast, stable
End of status
22/tcp    open  ssh           OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
|_ssh-hostkey:
|_  1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_  2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp    open  telnet        Linux telnetd
25/tcp    open  smtp          Postfix smtpd
|_ssl-date: 2025-03-08T05:59:17+00:00; -11m18s from scanner time.
|_ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
|_Not valid before: 2010-03-17T14:07:45
|_Not valid after: 2010-04-16T14:07:45
|_sslv2:
|_SSLv2 supported
|_ciphers:
|_SSL2_RC4_128_WITH_MD5
|_SSL2_RC4_128_EXPORT40_WITH_MD5
|_SSL2_RC2_128_CBC_WITH_MD5
|_SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
|_SSL2_DES_192_EDE3_CBC_WITH_MD5
|_SSL2_DES_64_CBC_WITH_MD5
5432/tcp  open  postgresql    PostgreSQL DB 8.3.0 - 8.3.7
|_ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
|_Not valid before: 2010-03-17T14:07:45
|_Not valid after: 2010-04-16T14:07:45
|_ssl-date: 2025-03-08T05:59:17+00:00; -11m18s from scanner time.
5900/tcp  open  vnc            VNC (protocol 3.3)
|_vnc-info:
|_  Protocol version: 3.3
|_  Security types:
|_    VNC Authentication (2)
6000/tcp  open  X11            (access denied)
6667/tcp  open  irc            UnrealIRCd
8009/tcp  open  ajp13          Apache Jserv (Protocol v1.3)
|_ajp-methods: Failed to get a valid response for the OPTION request
8180/tcp  open  http           Apache Tomcat/Coyote JSP engine 1.1
|_http-favicon: Apache Tomcat
|_http-title: Apache Tomcat/5.5
|_http-server-header: Apache-Coyote/1.1
MAC Address: 00:0C:29:FA:DD:2A (VMware)
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
|_smb2-time: Protocol negotiation failed (SMB2)
|_smb-os-discovery:
|_  OS: Unix (Samba 3.0.20-Debian)
|_  Computer name: metasploitable
|_  NetBIOS computer name:
|_  Domain name: localdomain
|_  FQDN: metasploitable.localdomain
|_  System time: 2025-03-08T00:59:08-05:00
|_smb-security-mode:
|_  account used: <blank>
|_  authentication_level: user
|_  challenge_response: supported
|_  message_signing: disabled (dangerous, but default)

TRACEROUTE
HOP RTT ADDRESS
1 1.46 ms 192.168.80.130

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 21.93 seconds
```

After the scan:

- After nmap -A 192.168.80.130 Scan
 - Analyze Scan Results → Check open ports, services, OS version, and vulnerabilities.
 - Identify Exploitable Vulnerabilities → Use searchsploit or CVE databases.
 - Exploit Vulnerabilities → Use Metasploit, Hydra, or manual exploitation.
 - Run Advanced Scans (If Needed) → Use nmap -p-, nmap --script=vuln, or SMB scans.
 - Secure the System (If Testing Own Network) → Close ports, update software, and improve security.